Despliegue en Vercel

El sitio del alumno se despliega en **dos proyectos de Vercel**, uno por pieza:

Proyecto	Contenido	Root Directory	Producción
`aprueba-api`	Backend Express (API REST) y su documentación	`aprueba/aprueba_student_web/backend`	https://aprueba-api.vercel.app
`aprueba-student-web`	Frontend web (Vite, estático)	`aprueba/aprueba_student_web`	https://aprueba-student-web.vercel.app

La API es un servicio propio porque la consumen varios clientes (la web, la app Flutter y la consola admin) y es el entregable del equipo ante la empresa. La especificación de la empresa la ubica en su propio dominio (`https://api.aprueba.cl/api/v1`).

Ambos proyectos están **conectados al repositorio**: al mezclar a `main` se despliegan a producción, y cada PR genera un Preview protegido con la autenticación de Vercel. Funciones en `gru1` (São Paulo), cerca del Firestore en `southamerica-west1` (Santiago).

Seguridad entre frontend y API

- **Sesión**: token JWT Bearer en la cabecera `Authorization`. Al no usar cookies, no hay superficie de CSRF.
- **CORS en la API**: solo el origen del frontend (`CORS_ORIGINS`) y sus previews (`CORS_ORIGIN_REGEX`, anclado siempre). Métodos y cabeceras limitados, y sin credenciales de navegador. La app móvil no envía `Origin` y no pasa por CORS.
- **Cabeceras del frontend** (`aprueba_student_web/vercel.json`): CSP estricta (scripts solo propios; conexiones solo a la API; estilos y fuentes propios y de Google Fonts; sin iframes ni objetos), HSTS, `X-Content-Type-Options`, `X-Frame-Options: DENY`, `Referrer-Policy`, `Permissions-Policy` y COOP. La CSP reduce el impacto de un XSS sobre los tokens guardados en el navegador.
- **Cabeceras de la API**: `helmet`.
- **La API no expone archivos**: su carpeta de salida es `backend/public/`, que solo tiene `robots.txt` y el favicon de la documentación. Sin ella, un proyecto sin build serviría como estáticos los archivos de la raíz, incluido el código fuente.
- **Mínimo privilegio**: el proyecto del frontend no tiene credenciales; la clave de Firebase y el `JWT_SECRET` solo existen en `aprueba-api`.

Pendiente ligado al dominio propio: la especificación pide el refresh token en una cookie `httpOnly` para la web. Entre `*.vercel.app` esa cookie sería de terceros (`vercel.app` es un sufijo público) y Safari y Firefox la bloquean. Se implementa cuando existan dominios del mismo sitio, como `app.aprueba.cl` y `api.aprueba.cl`, con `SameSite=Lax`.

Si cambia el dominio de la API, hay que actualizar tres cosas: `VITE_API_URL` del frontend, el `connect-src` de la CSP en `aprueba_student_web/vercel.json` y `CORS_ORIGINS` de la API si cambia el del frontend.

Variables de entorno

`aprueba-api` (Production y Preview)

Variable	Valor	Nota
`DATA_DRIVER`	`firestore`	
`FIREBASE_SERVICE_ACCOUNT`	JSON de la cuenta de servicio en base64	**Secreta.**
`JWT_SECRET`	Aleatorio, 32 caracteres o más	**Secreta.** Distinta en Production y Preview. Sin ella, el API no arranca.
`DEMO_MODE`	`true`	Atajos de prueba. **Apagar antes de tener usuarios reales.**
`PHONE_VERIFICATION_REQUIRED`	`false`	El frontend web no envía `phoneToken` al registrarse.
`CORS_ORIGINS`	`https://aprueba-student-web.vercel.app`	
`CORS_ORIGIN_REGEX`	`https://aprueba-student-(web-git-[a-z0-9-]+|[a-z0-9]+)-aprueba\.vercel\.app`	Previews del frontend.
`API_DOCS`	`protected` en Production, `public` en Preview	Ver `docs/documentacion-api.md`.
`API_DOCS_USER` / `API_DOCS_PASSWORD`	Solo Production	La contraseña es **secreta**.

`aprueba-student-web` (Production y Preview)

Variable	Valor
`VITE_API_URL`	`https://aprueba-api.vercel.app`

Se fija al compilar. Los previews del frontend también usan la API de producción: los previews de la API están protegidos por Vercel y un navegador no puede llamarlos desde otro dominio.

Cargar secretos sin imprimirlos

En PowerShell, desde la raíz del repositorio (cambiar `production` por `preview` para el otro entorno):

```
node -e "process.stdout.write(require('fs').readFileSync(process.argv[1]).toString('base64'))" "RUTA\AL\ARCHIVO-firebase-adminsdk.json" | vercel env add FIREBASE_SERVICE_ACCOUNT production --project aprueba-api --yes
```

```
node -e "process.stdout.write(require('crypto').randomBytes(48).toString('base64'))" | vercel env add JWT_SECRET production --project aprueba-api --yes
```

Nunca pegar estos valores en el repositorio, en un `.env` versionado ni en un chat.

Verificar

- API: `https://aprueba-api.vercel.app/health` debe responder `{"status":"ok", ..., "driver":"firestore"}`.
- Documentación: `https://aprueba-api.vercel.app/api/docs` pide usuario y contraseña.

- Frontend: iniciar sesión en https://aprueba-student-web.vercel.app con un usuario demo (contraseña `demo1234`):

Usuario	Plan
`demo@aprueba.cl`	`free`
`juan@correo.cl`	`uni`
`camila@correo.cl`	`all`

- Un Preview protegido se consulta con el CLI, que se autentica con la sesión:

```
vercel curl /health --deployment <url-del-preview>
```

- App Flutter:

```
flutter run --dart-define=API_BASE_URL=https://aprueba-api.vercel.app/api/v1
```

Previews y datos

Los Previews usan **el mismo Firestore que producción**: una prueba descuidada en un PR puede desordenar los datos demo. Si pasa, se restauran con el seed, que es idempotente (`backend/src/seed/seed.js`).

Notas

- **Arranque en frío**: la primera petición a la API después de un despliegue o de un rato sin uso tarda 1 a 2 segundos (carga de `firebase-admin`).
- **Plan Hobby**: es para uso no comercial.